English edition · Version 1.0

Maximum Compliance, Quality and Governance and Minimum Data Use Document

The institutional reference adopted internally by Rijal Alwatan Holding Company

A simpler experience, less data, and accountable decisions supported by evidence

Prepared by Ismail Al-Tamimi

Institutional reference adopted by Rijal Alwatan Holding Company

5 November 2026

Interactive contents

Interactive contents

Select a chapter title to jump to it. The Contents button on every page returns here.

01 Internal Adoption and the Simplification Gate . . . 3
02 Applicability, Responsibilities and Decision-Making Authority . . . 3
03 User Journeys, Dashboards and Accessibility . . . 4
04 Data Purposes, Minimisation and Legal Bases . . . 5
05 Notices, Consent and Data Subject Rights . . . 6
06 Processing Records, Published Policies and Assessments . . . 7
07 Retention, Destruction, Suppliers and Transfers Abroad . . . 8
08 Institutional Accounts, Identity and Permissions . . . 8
09 Server-Side Enforcement, APIs and Files . . . 9
10 Action Logs, Audit and Tamper Resistance . . . 10
11 Reading Logs and Authorised Export . . . 11
12 Environments, Releases, Maintenance and Implementation Quality . . . 12
13 Incidents, Data Breaches and Notification Decisions . . . 12
14 Containment, Recovery, Backups and Continuity . . . 13
15 Commerce, Payments, Invoicing and Regulated Features . . . 14
16 Rights in Works, Content and Artificial Intelligence . . . 15
17 Flexible Identity and Independent Cloning . . . 16
18 Sale, Gift and Transfer of Ownership or Operations . . . 16
19 Technical Personnel Offboarding, Operational Independence and Handover . . . 17
20 Websites, Web Applications and Progressive Web Apps . . . 18
21 Mobile Apps, Distribution, Permissions and App Transfer . . . 19
22 Acceptance Gates, Alignment, Use and Corrections . . . 20
23 Reference sources . . . 22

01 Internal Adoption and the Simplification Gate

An internal reference that starts with ease of service and connects due care to decisions supported by evidence.

This document is the institutional reference adopted internally by Rijal Alwatan Holding Company for the governance of websites, web applications, progressive web apps and mobile applications, from establishment through alignment, operation, cloning, transfer, isolation and shutdown. It is an internal reference. Each provision applies according to the product's activity and the applicability of the law. Its applicable requirements become specifications, responsibilities and acceptance evidence in the product file.

The Highest Priority

The expressly stated highest priority is to simplify and ease the experience of visitors, users, owners, the principal administrator, administrators and relevant authorised parties. Each role must have an appropriate dashboard and short steps that retain preferences and progress to the extent needed, without repeated data entry or consent requests, unnecessary registration or blanket blocking. The backend automatically enforces server-side controls. Required notices, consents, rights and material costs appear where they are relevant.

The Meaning of Maximum and Minimum

The ambition expressed in the title is a goal of quality and professional care. It is not a guarantee of immunity, freedom from incidents or freedom from maintenance, nor a certificate of government accreditation. Minimum data use means limiting data to what is needed for an approved purpose, not eliminating data required by law or for a service. Simplicity of experience is a testable objective, not a promise that every control or consent will have no effect whatsoever on the user journey.

The Decision Gate Before the Feature

- Identify the user's need, the activity and the required data before selecting technology or adding accounts.
- Assign responsibility for decisions, implementation and review, and link each acceptance to a version and evidence of performance and rights.
- Keep lawful public services available, and restrict blocking to the function whose conditions have not been met.

> **The Governing Rule**
>
> Hide operational complexity, not the truth, rights or costs. Place controls behind the service rather than making them a blanket barrier to it.

02 Applicability, Responsibilities and Decision-Making Authority

Every requirement has a clear classification, and every decision has an accountable owner and defined limits of delegation.

Classifying Requirements

The starting point is the laws and regulations in force in the Kingdom of Saudi Arabia. Mandatory legal provisions must be distinguished from activity-specific or sector-specific conditions, provider or app-

store policies, and institutional standards. In this reference, 'must' denotes an internal requirement within its scope; it does not label every recommendation as a general law. For each obligation, retain its article or section, version, reason for applicability and the person responsible for keeping it up to date.

National Cybersecurity Authority controls apply according to their scope, which includes government entities and their affiliates, and private-sector entities associated with critical national infrastructure. The full set is not imposed on every private website. Digital Government Authority requirements are examined where the activity is governmental or is delivered on behalf of a government entity. For entities outside those scopes, a proportionate level of protection is adopted in line with the duty to protect and recognised best practices.[2][4]

Roles That Do Not Automatically Merge

Distinguish the asset owner and rights holder from the controller, which determines the purposes and means of processing; the processor acting on its behalf; the technical operator; and the principal administrator. The owner decides on delegation, budgets and material transactions. The controller approves data purposes and their legal bases. Operations personnel and the developer implement controls within their respective assignments. The title of principal administrator does not, by itself, confer a right to access all personal data.[1]

The Scope File

- Document the entity, service, audience, markets and sector, together with accounts, data, suppliers, payments, content and regulated features.
- Identify the status of each feature: not applicable, under classification, approved within a defined scope, or suspended.
- Name the person authorised to decide on launch, shutdown and transfer, the specialist reviewer and the operational alternate, even if one person holds more than one role.

> **A Decision the Tool Cannot Override**
>
> Do not start a regulated function before classifying it and obtaining any required authorisation. Acceptance of risk does not permit a breach of law or the denial of a mandatory right.

03 User Journeys, Dashboards and Accessibility

Simplicity is measured by completing the right task, not by hiding required steps.

Service by Role

Visitors begin by browsing public content without an account where the function permits. The user dashboard presents the user's services, requests and choices. The administrator dashboard presents tasks within that administrator's scope. The principal administrator dashboard presents management decisions and the action log. The owner dashboard presents the status of assets, risks and approvals without overwhelming the owner with technical detail. Relevant authorised parties see only the materials permitted by the request and authorisation, through a clear, limited process.

Necessary preferences and progress must be retained in a disclosed and secure manner, with a clear distinction between a saved draft and an executed action. Reuse valid data already held instead of asking the person to provide it again, without retrieving data outside the person's purpose. Present errors beside the relevant field in understandable language, retain valid inputs, and allow the person to go back and correct errors before committing. Do not request an existing consent again merely because the screen changes.

Arabic and Accessibility

WCAG 2.2 Level AA is adopted as an institutional quality target, together with any additional applicable requirement. This is not a claim that it is a uniform obligation for every Saudi website. Set Arabic right to left and English left to right. Isolate numbers, email addresses and links in the appropriate direction without breaking them apart. Review contrast, keyboard use, focus, labels, zoom, screen readers and accessible authentication.

Evidence of the Experience

Define acceptance journeys for each role, covering visits, requests, refusals, withdrawals, complaints, exports and sensitive administration. The responsible person documents steps, repetition, obstacles, observed time and cost clarity, then approves improvement targets against the baseline. Do not use fabricated performance figures. Combine automated checks with human review of the full journey. An accessibility button is not a substitute for fixing the interface.

> **Testable Simplicity**
>
> If a step can be reduced without compromising a right or necessary protection, it must be reduced. If a step is necessary, its reason must be explained and its completion made easier.

04 Data Purposes, Minimisation and Legal Bases

No field without a defined need, and no processing without a legal basis and an accountable party.

The Purpose Register

Before collection, each purpose, data category, source, legal basis, responsible party, recipient and supplier must be identified, together with its retention period or end criterion. The field map links each need to its purpose and covers forms, files, logs, background tasks and derived outputs. Consent is not the default for all processing. Examine the legal basis for each purpose under the law and document its conditions before putting it into operation.[1][2]

Do not collect a national ID number, date of birth or telephone number, or create an account, without a genuine need or applicable requirement. Do not collect sensitive data or enable analytics, tracking or external artificial intelligence by default. If the activity requires an exception, approve its scope, assessment and controls first. Request the data when the function that needs it is used, not on the first visit.

Public Does Not Mean Unrestricted

Published data about individuals remain subject to the provisions governing them. Public availability does not provide a blanket legal basis for recollection, republication or training. The lawfulness of the source and purpose, proportionality, and notification where applicable must be verified. Pseudonymisation, including replacing a name or hashing a linkable identifier, is not anonymisation. The data remain personal if re-identification is possible. Anonymisation requires an assessment of how effectively direct and indirect identifiers have been removed.[1][2]

Minimising Operational Telemetry

Do not automatically store the raw network address in every event or the full request body in error logs. Select the minimum fields needed for protection or audit, with a legal basis, retention period and access permissions. Redact secrets, tokens and private messages. Where legitimate interests are adopted as the legal basis, document necessity, balancing and reasonable expectations. Sensitive data do not fall within this legal basis.[2]

The Collection Barrier

An undefined purpose, an unapproved legal basis or an unnecessary field is a reason to stop the processing concerned before launch, not a reason to add a general consent that merely purports to cover it.

05 Notices, Consent and Data Subject Rights

Rights require clear implementation processes, not token checkboxes or pages.

Information and Choice

Make the privacy policy available and provide information before or at direct collection: the controller's identity and contact details, the purpose and legal basis, whether fields are mandatory, recipients, retention, rights and any transfer abroad. An audit log does not replace a notice. For indirect collection, notify without unjustified delay and within thirty days of receipt, including the categories and source, unless a documented applicable exception applies.[1][2]

Separate acceptance of terms from awareness of the policy and from optional consents. Where consent is relied upon, it is freely given, clear and separate for each purpose, and recorded with the time, method and text version. Provide a withdrawal mechanism comparable to, or easier than, giving consent. Stop the purpose on the server, in queues and with suppliers without unjustified delay. Refusing marketing does not block an unrelated service. Do not replace withdrawn consent with a retrospective legal basis to circumvent the withdrawal.[2]

Easy Requests and Proportionate Verification

Provide practical channels for information, access, a copy, correction, completion, updating, destruction and complaints, as appropriate to the service, without requiring an account or subscription solely to exercise a right. Use an authenticated session or an alternative channel for proportionate verification. Do not request an ID image from every requester. Record requests, including oral requests, the receipt time, responsible person, deadline, decision, response and evidence of implementation.[1][2]

Time Limits and Implementation

Implement rights requests without delay within a period not exceeding thirty days. The period may be extended by no more than an additional thirty days where unexpected or unusual additional effort is required, or where the person makes multiple requests, with advance notification of the reasons for extension. Transferring operations does not restart the clock. Protect the rights of others in the copy, and propagate correction and destruction to the relevant systems and recipients.[2]

Genuine Completion

The request button starts the process. Completion requires an understandable response and documented implementation, explaining any lawful retention or applicable restriction, not a promise of immediate deletion of every copy.

06 Processing Records, Published Policies and Assessments

The reference provides overarching governance; the published policy truthfully describes a specific service.

An Up-to-Date Institutional Record

A record of processing activities must be created and linked to the data map, purposes, legal bases, recipients, suppliers, retention, transfers, measures and responsible parties. Retain the activity record throughout processing and for five years after the processing activity ends, in accordance with the Regulation. This is the retention period for the activity record, not a general retention period for user data. Review the record when a field, purpose, supplier, country or material function changes.[2]

Checking Applicability

Examine whether a data protection impact assessment is required before processing, according to the Regulation's triggers. These include sensitive data, linking multiple sources, specified large-scale or repeated activities, emerging technologies, or the possibility of serious harm. Examine whether a data protection officer must be appointed under the relevant conditions; do not designate every technical administrator as an official officer. Where required, define the officer's independence, resources, communications and alternate, and examine registration requirements applicable to the controller.[2]

A Policy of Facts, Not Templates

Draft a privacy policy for each product from its actual decisions, contracts and settings. Cover identity, contact details, categories, sources, legal bases, purposes, tracking, recipients, transfers, retention and rights. Do not publish empty fields or statements such as 'we do not collect', 'we do not transfer' or 'not used for training' without facts to support them. This reference is not the published policy for every activity and does not replace its adaptation and approval.

Draft concise, clear terms covering the service scope, eligibility, costs, renewal, cancellation, content rights, complaints, suspension and deletion, with a commerce annex where applicable. Retain versions, effective dates, acceptance dates and the text accepted at the time of contracting. A new owner does not rewrite past terms or invoices. The terms do not include unlawful exclusions of liability or denial of the rights of data subjects, consumers or competent authorities.[1][14]

Testable Consistency

The team must be able to substantiate every published claim through the service's behaviour and a decision record. Text that cannot be implemented or substantiated must not be published as fact.

07 Retention, Destruction, Suppliers and Transfers Abroad

The end of a purpose is an operational decision. Server location is part of the flow, not the whole of it.

A Period for Each Category

Approve a start date, period or end criterion, legal basis and responsible party for each category. Destroy data without delay once the purpose ends, subject to legally required retention or a hold relating to a pending case and necessary for it, within its limits. Isolate data retained for that reason from other uses and review when the reason ends. Possible future need does not justify open-ended retention. Logical deletion alone is not destruction.[1][2]

The destruction plan covers databases, files, indexes, caches, suppliers and backups. Use data-minimised deletion references or markers that prevent data from being revived, so that the latest destruction, correction and withdrawal decisions are applied before a restored copy is opened. This mechanism does not replace destruction of copies when due. Substantiate implementation with results and limited references, and define the retention period of the deletion record itself.[2]

The Supplier and Its Role

Inventory each supplier, its legal entity, service, roles, countries of processing, access and copying, subcontractors, contract, approval status and exit path. The processor's contract defines the purpose, categories, duration, instructions, safeguards, cooperation on rights and destruction, and notification of the controller of a breach without unjustified delay, together with applicable approvals for subprocessors. Document periodic verification of compliance, rather than merely possession of a certificate used in marketing.[2]

Examining the Flow

The map covers hosting, email, messaging, support, analytics, content delivery networks, protection, backups, recovery, remote access and artificial intelligence. Do not assume that all data of every private website must be localised. Hosting a database locally is not enough to rule out transfers. Establish the legal basis for processing and the route, conditions, safeguards and risk assessment for transfers abroad where applicable. Consent or contractual clauses alone are not a substitute for the conditions of the transfer route and sector.[1][3]

A Manageable Exit

Before approving a supplier, the retrieval format and cost, destruction method and evidence, and alternative supplier must be known. A supplier that cannot be exited is a risk requiring a decision, not concealment.

08 Institutional Accounts, Identity and Permissions

Institutional control is independent of an individual's account, and privilege is limited to need.

Account Ownership and Administration

Domain, repository, hosting, service, app-store, billing, renewal and recovery accounts must be under the control of the institution or an authorised entity. Individuals use named individual accounts with invitations and roles. Their personal account passwords are not shared, nor are their identities handed

over as company assets. The asset register identifies the account owner, custodian, recovery method, alternate and transfer restrictions.

Authentication and Sessions

Establish identity through an authenticated server-side session or an approved identity provider. Do not rely on a client-supplied header such as X-User-ID to establish the actor's identity. Adopt multi-factor authentication for sensitive accounts and step-up authentication for sensitive actions, such as managing privileges, exporting and changing the operating entity, without blanket re-verification on every navigation. Protect recovery with the same care as sign-in. Support personnel do not choose the user's password.

Renew sessions when privileges change and invalidate them server-side on sign-out, disabling or revocation. Address access tokens, refresh tokens and provider authorisations according to their respective types. Set durations according to risk, and store passwords using secure salted derivation with trusted components. Protect session cookies and their settings. Deleting a cookie alone does not invalidate every means of access.

Least Privilege and Controlled Recovery

Limit the permissions of people and service identities by action, resource, environment, duration and purpose. Separate writer, reader, custodian and approver roles where sensitivity requires. Define emergency access with a reason, duration, monitoring and review. Document the setup of the first administrator through a limited, independent invitation and the recovery method if the service or responsible person becomes unavailable, without a hidden account or permanent developer master key.

> **Limited Authority**
>
> The owner and principal administrator have defined decision-making powers, not permanent permission to read all personal data. Every access requires a function, purpose and authorisation.

09 Server-Side Enforcement, APIs and Files

Trust is established on the server. Hiding a button does not protect the object.

Multi-Level Authorisation

The action, object, field and tenant must be checked server-side on every path, including search, download, export and background workers. Derive the entity's scope from authenticated identity and verified membership, not solely from a client-supplied identifier. Adopt separate allowlists for readable and writable fields. Do not return a complete internal row and rely on the browser to hide parts of it. Editing a profile must not allow the role or owner to be changed.

For every API, document the input and response schemas, authentication, resource scope, purpose, side effects, rate limits, size limits and timeouts. Enforce proportionate quotas by action, account and entity. Transactions and reliable constraints prevent duplicate payments or submissions when a request is retried. Recheck permissions, consent and resource status when a deferred task executes, not only when it is queued.

Secure Inputs and Connections

The server validates types, sizes and values. Use parameterised queries, context-appropriate output encoding and sanitisation of permitted content. Protect state changes against cross-site request forgery (CSRF), and adopt TLS, certificate validation and a content security policy (CSP) appropriate

to the features. Do not impose an absolute security header that disables legitimate embedding or functionality without assessment. CORS is not user authorisation.

Files and Integrations

Check files by actual type, size and decompression limits. Quarantine and scan them using proportionate anti-malware protection before making them available, and prevent execution. Use an authorised download or a signed link with limited duration and scope. Check fetch destinations, redirects and unauthorised networks. Verify supplier notifications, their signatures and request status against the trusted source. Provide understandable failure messages that do not disclose private details.

> **The Trust Boundary**
>
> Successful authentication does not establish the right to act, and successful authorisation does not create a legal basis for processing. Both must be satisfied without burdening the user with enforcement details.

10 Action Logs, Audit and Tamper Resistance

The original event remains unchanged during retention. A correction is a new, traceable record.

A Read-Only Log

The principal administrator dashboard must present a read-only action and audit log that no user, administrator or developer can manually edit or delete during the retention period. Implement append-only storage, WORM, or an equivalent assurance substantiated by the technology provider. Separate writer, reader and storage custodian permissions, and apply a retention lock that the application administrator cannot override.

Substantiate tamper resistance and detection by documenting trust boundaries, source settings and independent evidence, such as protected integrity verification outside the write path. Do not claim that a cloud owner with privileges beyond those boundaries cannot make changes. Correct an event error by appending a correction event linked to the original, its reason and its approver, without changing the original. Carry out periodic destruction after the purpose and period end, subject to a controlled, reviewed lawful hold, rather than retaining records forever.

Event Content

According to significance, record sign-ins and their outcomes, roles, viewing or exporting sensitive data, consents, rights, changes of owner, cloning, transfers, technical work, settings, launches, backups, destruction and incidents. Attribution rests on an authenticated server-side identity. Include the actor reference, role, entity and scope; the action, object, outcome and reason where relevant; the time, correlation identifier, and policy or decision version. Do not include secrets or raw sensitive bodies.[5]

Assurance of Preservation

Link a critical action and its event through a transaction and durable event outbox, a fail-safe mechanism, or a reliable outbox with retries and duplicate control. This must demonstrate that no critical effect is committed without a preserved audit record. A temporary task after the response is not sufficient evidence of delivery. Non-critical events may be handled in the background, with loss monitoring, alerts and remediation. The classification policy defines what is critical instead of logging every click at the same cost.

Minimum Evidence

The log establishes a sequence that can be examined within its boundaries. A signature or timestamp alone does not make it conclusive evidence, and it does not replace a valid notice or lawful decision.

11 Reading Logs and Authorised Export

A clear button, a minimal scope, and a verifiable copy.

Task-Based Views

Each person sees only what their function requires. The principal administrator screen does not grant unrestricted access to personal data. Separate role management from sensitive access, minimise displayed fields and mask identifiers where a reference is sufficient. The dashboard provides understandable searches by event, scope, period and outcome, and explains restrictions rather than overwhelming the administrator with unnecessary detail.

Simple, Defined Exports

A simple export button must be provided within the user's permissions, specifying the entity scope, period, category, minimisation level and format. Use CSV or JSON for processing, and a secure, readable PDF where an understandable copy is needed, explaining the fields and limitations. Redact data before generating the file. Handle CSV fields that could be interpreted as malicious formulas so that opening the report does not become a channel for execution or leakage.

Link the copy to its creation time, schema version and identifier, and provide a signature or hash to verify integrity through a trusted channel. Deliver the file through a temporary link or protected channel. Notify the requester when the export is complete, and record the request, decision, execution and download where the latter can be observed. Define the file's retention period and destruction, and recheck permissions when execution is deferred. Do not send a comprehensive attachment to an unverified email address.

Requests from Relevant Authorised Parties

Before disclosure, document the party's request, the requester's capacity, the basis for the request and its scope. The specialist reviewer examines what may be provided and what must be withheld. Deliver only the minimum necessary material in an understandable format, without disclosing others' data or all logs merely because a download button is available. Retain the request, decision and evidence of delivery according to applicable retention requirements. Keep incident files and sensitive evidence out of public view.[1][2]

Secure Facilitation

Ease of export means reducing authorised effort, not expanding the requester's permissions or removing redaction and retention controls.

12 Environments, Releases, Maintenance and Implementation Quality

Every change has a preserved scope and rollback evidence. Production does not depend on an individual's device.

Separating Operations and Development

Production, development, testing and recovery must be separated, including accounts, databases, files and secrets. Technical personnel use synthetic data, not production data, by default. Any exceptional access to production requires a documented need, least privilege, a duration, approval and a log. Store secrets in a dedicated vault, not in source code, the browser, build artefacts or support tickets.

A Controlled Release Pipeline

Review code and configuration changes, and control merge and CI/CD deployment permissions through institutional service identities. Retain dependency versions, the software bill of materials (SBOM), licences, and the results of secret, code, vulnerability and business-logic checks. Acceptance is linked to a defined version, environment and scope, not a general success badge. Assign responsibility for following up security patches, dependencies, renewals and policies.

Before transition, migration or a change of supplier, preserve a restore point for code, settings, decisions, schema state and protected data where needed. Select compatible migrations and a rollback plan covering the schema, files, tasks and supplier, not just a code rollback. Rollback does not revive a withdrawn purpose, revoked permission or data due for destruction. Keep those decisions separate from the interface version.

Proportionate Quality Evidence

Define unit, integration, regression, performance, security and journey tests according to risk. Document actual results, failures, measurement limitations, the responsible person, remediation and the review date. Performance targets rest on a baseline, contracts and product needs, not fabricated statutory figures. Independence and organised maintenance reduce dependency and cost; they do not eliminate updates or the need for a specialist.

> **A Targeted Change**
>
> What will change and what must remain unaffected must be identified, preserved and checked. Alignment is not permission to rebuild sound functions outside the scope.

13 Incidents, Data Breaches and Notification Decisions

An alert begins an assessment. Awareness is a documented point in time that is not re-dated.

Classification and Separate Times

A monitoring baseline must be maintained, and an incident record opened that distinguishes cyber incidents, data breaches and outages. Not every alert or failed sign-in is a breach. Accidental disclosure, unauthorised internal access or corruption may constitute a breach without public publication. Record the known or estimated occurrence time, alert time, awareness time and its basis, and actions taken. Separate facts from estimates and revisit the decision when new information emerges.[2]

Notifying the Authority and the Data Subject

Where the condition in Article 24/1 is met, the controller notifies the competent authority within a period not exceeding seventy-two hours of becoming aware of the incident if it may harm the data or the data subject, or conflict with the data subject's rights or interests. Do not wait for the investigation to finish in order to restart the time limit. Send an initial report with what is known, clearly marking estimates. Complete unavailable information as soon as possible, with reasons for delay in accordance with the provision.[2]

Notify the data subject without unjustified delay where the condition in Article 24/5 is met: the possibility of harm to their data or conflict with their rights or interests. Do not apply a general seventy-two-hour deadline to that notification. The notification clearly explains the event, risks, measures, contact details and appropriate advice, without requesting a password or verification code. Retain reports, updates and evidence of sending in an access-restricted file.[2]

Multiple Obligations and an Alternate Responsible Person

Review other duties according to the sector, commerce, applicable controls and contracts, and maintain a separate clock for each recipient and threshold. The processor notifies the controller without unjustified delay under the Regulation and contract, not after exhausting the controller's time limit. Define the incident lead, authorised notifier, alternate, official channel, clock source and evidence of attempted notification. Do not assume that channel failure suspends the time limit.[2]

> **Controlled Disclosure**
>
> Do not display incidents to the public on a public dashboard. Necessary information reaches authorised persons, affected persons and entitled authorities without downplaying the event or making unsubstantiated accusations.

14 Containment, Recovery, Backups and Continuity

Restoration brings back a sound service and effective rights, not merely a working page.

Proportionate Containment

The on-call person must have a procedure for escalating incidents, preserving evidence at risk of loss, isolating the affected path or identity, and invalidating relevant sessions or integrations. Preserve lawful functions where possible through a limited, safe operating mode. Do not use automatic blanket blocking to punish users. Investigation, notification and containment proceed in parallel, with reasons, responsible persons and times recorded.

Maintain the chain of custody of evidence, including source, time, transfers, permissions and integrity. Prevent secrets and raw data from being copied into public tickets. Address an exposed secret at its source, review how it is used and the privileges it unlocks, and substantiate rejection of its old value. Do not destroy an encryption key needed for lawful copies without a re-encryption or recovery plan. A data decryption key is different from a service access token.

Isolated, Tested Recovery

Adopt encrypted, isolated backups according to risk, separating backup administration and keys from the production path exposed to harm. Restore to an isolated environment from a clean source. Check transactions, files, permissions and dependencies, and apply the latest deletion, correction and withdrawal decisions before gradually reopening traffic. The owner sets the acceptable data loss, or recovery point objective (RPO), and the recovery time objective (RTO), according to service impact, contract and sector, without fabricated mandatory values.

Closure and Improvement

The service owner accepts the recovery report, its integrity, gaps and monitoring for recurrence. Notification updates continue where needed. Document the root cause, fixes, responsible persons and verification evidence, and review supplier, recovery and on-call controls. Appropriate exercises, restorations and tests must be conducted, with results recorded when performed. Do not describe a procedure proposed in this reference as a successful exercise or a test of a particular platform.

> **Practical Acceptance**
>
> Successful backups do not prove successful restoration, and service recovery does not rule out a data breach. Each outcome requires independent evidence and an accountable decision.

15 Commerce, Payments, Invoicing and Regulated Features

The offer, cost and rights are part of the service. Classification comes before collection of payment.

A Clear Contract and Cost

Where e-commerce requirements apply, the service provider's capacity, identity and contact details, the product or service characteristics, total price, fees, taxes, delivery, performance and warranty must be disclosed before commitment. Clarify the step that forms the contract and creates the payment obligation. The process allows data to be reviewed and corrected, and preserves the offer, terms and receipt at the time of contracting. Do not label an order-receipt message as a confirmed contract if it is not one.[14]

Subscriptions disclose payment amounts and frequency, renewal, the next charge, cancellation and its effects, without hidden fees or misleading choices. Draft cancellation and refund policies according to categories, statutory rights and applicable exceptions. Do not adopt a blanket refund ban or substitute store credit for a refund that is due. Provide a simple channel for complaints, warranties and order correction. Do not use intermediary status to deny an actual role.[14]

Payment Through an Authorised Provider

Use a payment provider licensed for the appropriate scope, verifying the provider's legal entity and service type. Hosted payment or provider-hosted fields are preferred to avoid storing the full card number. Storing the card verification value (CVV) in the product or logs is prohibited. Retain only the minimum necessary transaction reference and invoice. The server verifies the amount, currency, order, trusted notification, duplicate prevention and refund, rather than relying solely on the browser's return.[16]

The Sector and Tax Gate

Examine invoicing and tax according to the establishment's status, the supply and the integration phase applicable to it. Apply ZATCA requirements within their scope, without treating every receipt as a tax invoice or every website as subject to integration. Preserve historical invoices and correct them through applicable procedures, not by changing the current identity.[15] Suspend regulated wallet, transfer, investment, health, real-estate, education or government-service functions until classification and the required licence or approval are completed. Prevent server-side execution of any suspended function.

Facilitation Without Concealment

Bring cost, commitment and rights information together at the point of decision. Do not turn compliance into a lengthy screen or hide material information to shorten the journey.

16 Rights in Works, Content and Artificial Intelligence

Rights derive from a clear legal instrument. A tool does not grant an automatic licence.

Rights Instruments and Licences

The sources of code, designs, marks, fonts, images, content and versions, together with rights holders, licences and restrictions, must be documented. An express written contract is required to define deliverables, economic rights transferred or licensed, their duration and scope, and rights to modify, build upon, reuse, clone, distribute and assign, according to the valid agreement. Distinguish third-party components and the contractor's pre-existing tools. Possession of the repository, an ownership header or payment of an invoice is not sufficient to establish all rights.[13]

Review open-source licences, commercial dependencies and attribution, distribution and availability conditions, without assuming that every library requires publication of the entire product. Separate ownership of the work from the mark, domain, contracts and service accounts, and preserve moral rights that cannot be waived. Do not use an entity's logo or an unauthorised accreditation or partnership badge to complete the institutional appearance.[13]

User Content and Reports

When accepting user content, define a licence limited to hosting, display and necessary conversion. Do not infer a right to training or advertising. Provide a reporting, review and objection channel, and a proportionate process for disabling content and its derivatives where applicable, retaining limited evidence and protecting the parties' rights. Not every report establishes a violation, and terms of use do not grant blanket immunity from the platform's responsibilities.

Artificial Intelligence for an Approved Purpose

Do not enable external artificial intelligence by default. When it is approved, define the purpose, data, supplier, storage, training, human review, countries, duration and shutdown, minimise inputs and redact secrets. Explain its role and the limitations of its outputs to the user, and provide an appropriate human channel. Enforce tool permissions outside the model and treat documents and outputs as untrusted inputs. A disclaimer does not permit a regulated service without authorisation or guarantee exclusive rights in outputs.[1][2]

Authorised Use

Available or automatically generated content is not automatically free of individuals' and third parties' rights. Approve use after examining the purpose, legal instrument and data.

17 Flexible Identity and Independent Cloning

The core can be reconfigured. A new copy is independent and empty by default.

Settings Separate from the Core

Business logic must be separated from brand identity, legal entity, privacy, operations, infrastructure and app-store distribution. Use settings with a validation schema, allowlists, types, references, versions, effective dates, a change log and approval. Editing an entire configuration object must not allow the controller, administrator or payment keys to be changed without a dedicated process. Do not derive the controller automatically from the asset owner.

- Identity: Arabic and English names, logo, colours, fonts, domain, language, links and contact channels.
- Entities and policies: asset owner, rights holder, operator, controller, new administrator, and versions of terms, privacy and retention policies.
- Resources: unique platform and tenant identifiers, databases, files, storage buckets, search, queues, backups, service identities and secret references that are independent or demonstrably separated.
- Integrations and distribution: OAuth registrations, return URLs, email, payment, notifications, app-store identifiers, signing and security assets where present.

An Empty Copy

The new copy starts with a schema and only synthetic data or licensed public content. It contains no customers, accounts, consents, original audit log, secrets, sessions, tokens or private subscriptions. Create a new administrator invitation and new contact channels. Do not inherit the former owner's or operator's data as default settings. External integrations remain disabled or in testing until approved.

Acceptance of the Copy

Isolation testing substantiates that the copy cannot access the original's resources through APIs, files, search, caches, tasks or backups. Check identity in outputs, email, notifications, documents and links, not only on the first page. Variables ease configuration but do not create cloning rights, all resources or app-store acceptance. Review Apple's template-app policy, including clause 4.2.6, according to the experience and content provider.[11]

> **The Cloning Boundary**
>
> Independent cloning is not the transfer of a service with its accounts. Any introduction of real data requires a separate transfer plan, legal bases and approvals.

18 Sale, Gift and Transfer of Ownership or Operations

Rights and assets transfer according to their legal instruments. Data are not automatically included in the sale.

Defining the Transaction and the Parties

A transition starts with a decision distinguishing a sale of shares with continuation of the legal entity from a sale of platform assets, a gift or assignment, a change of operator without changing the owner, and a hosting transfer. Identify the owner of each asset, rights holder, controller, processor, operator and administrator before and after the effective date. A change of shareholder or owner field does not, by itself, change the controller or all contracts.

A Separate Package for Each Category

The transition register separates code, the work, marks, licences, contracts, domains, cloud accounts, suppliers, payment, app stores and data. Review the instrument supporting each right and its transferability, party consent, and the conditions of the supplier, domain registrar, sector and app store where required. Sharing a personal account password is not an institutional transfer. Success of a migration tool does not authorise transfer of a non-transferable contract or asset.

The departing entity examines the legal basis for disclosure, and the receiving entity examines the legal basis for collection and processing, together with purposes, notices, retention and transfers abroad. An asset sale contract does not permit the transfer of all customer data. An old marketing consent is not permission for an independent product. Initial due diligence uses synthetic data or redacted material. Any necessary access to real data is approved before it is made available.[1][2][3]

Stages and Closure

Approve the inventory, rights, risk plan and rollback plan, then conduct isolated verification and complete external approvals. Next establish resources and secrets, build, deploy, carry out permitted migration and obtain acceptance, then effectively revoke previous access methods. Retain a restore point and a formal record for each stage. Rights requests continue on their existing timelines, and historical contracts, invoices and consents are preserved. Do not describe the process as complete before operational acceptance and fulfilment of applicable obligations. Do not assume full, immediate completion for every supplier or device.

> **Taking Effect, Not Rewriting History**
>
> The transition event defines what has begun and what remains. A new identity does not erase past obligations or reattribute past documents to another entity.

19 Technical Personnel Offboarding, Operational Independence and Handover

The ability to replace a team is substantiated by source code, documentation and revocation of access methods.

An Inventory of Access Methods

Memberships, sessions, SSH and deploy keys, tokens, service identities, CI/CD permissions, OAuth applications, integrations, webhooks, email, domains, DNS, backups and recovery methods must be inventoried. Removing membership alone is insufficient. GitHub confirms that a repository deploy key may remain active after its creator is removed, so it is reviewed and disabled separately.[6]

Verified, Safe Revocation

Transfer ongoing functions from individual identities to approved institutional identities. Then invalidate the relevant sessions, keys and authorisations, rotate secrets the person had access to, and substantiate rejection of old access methods. Review recent changes, backdoors and external destinations without disabling lawful services or destroying decryption keys needed for lawful recovery. Do not claim to have erased copies already downloaded beyond the institution's control. Address obligations and investigation according to the case.

A Rebuildable Handover

The package includes source code, version history, designs, the data schema and dictionary, APIs, architecture, configuration descriptions, infrastructure as code where used, build tools, dependencies, licences, and the register of assets, suppliers and renewals. Deliver secret references through secure

channels, together with permitted deployment, monitoring, recovery, backup, restoration, rollback and incident runbooks, open tasks and specialist contact channels, without unnecessary bulk copying of personal data.
A replacement team that did not participate in creation rebuilds, deploys and restores from source code and documentation, without the former technician's device or account. Document the test, version, environment, results and limitations. Check attempts to use former access methods and the continued operation of authorised service identities. Delivering an executable or a statement of readiness does not establish independence. Replacing technical personnel does not cancel the duty of maintenance.

> **Demonstrable Independence at Handover**
>
> Do not approve the package until the replacement team can understand and operate it in an authorised test. Close critical gaps or define the scope to be blocked and the person responsible for remediation.

20 Websites, Web Applications and Progressive Web Apps

Controls increase as functions increase, not merely because the product's name changes.

A Website with Proportionate Requirements

An informational website may need only files, content, licensed assets, a domain, HTTPS connectivity, secure publishing control, a backup and restoration instructions. A visitor account or customer database is not required. For a contact form, approve the minimum fields, receiving destination, notice, server-side protection, abuse limits and understandable failure messages, and substantiate receipt of the request. Privacy covers hosting and service logs even without a form. Do not hide necessary disclosures behind the administration dashboard.

Interactive Web Applications

Accounts and transactions add an authenticated session context, server-side authorisation, restricted APIs, an audit log, a rights and retention lifecycle, tasks, migrations and backups. Public resources remain available without an account according to their purpose. Test rejection of object, entity or field substitution, and of revoked sessions and roles, while authorised paths succeed. No particular technical framework, database product or mobile application is assumed.

PWAs According to Their Features

Installability is adopted according to a valid manifest, a secure connection and support on the target browsers and devices. A service worker is not a general condition for installability itself. Use one where offline operation, storage or a supported feature requires it. Web access remains an alternative where installation is unavailable.[7] Do not place user identifiers or tokens in the launch URL or public settings.
Default caching is limited to public assets. Exclude private responses, accounts and attachments from cache rules. Sign-out clears account data locally and invalidates the session server-side. Recheck the authorisation of a deferred request when connectivity returns. Document the worker update lifecycle, cache versions, compatibility and preservation of unsent work, and test old tabs and clients. The browser is not a backup, and revocation does not guarantee wiping an offline device or a file that has left institutional control.

Acceptance by Type

The website must be tested within its limits, the web application by its functions, and the PWA by its installation, caching and updates where present. Success of one does not establish acceptance of another.

21 Mobile Apps, Distribution, Permissions and App Transfer

App-store identity, signing and linked services follow paths independent of the web.

Accounts, Identity and Distribution

The institution or authorised entity must control distribution accounts and team authorisations, app identifiers, signing, renewals, testing and release channels. Examine the actual distributed build, deep links, registrations, destinations and secure storage. Match app-store disclosures to the SDKs, their data and suppliers. A hybrid wrapper does not remove mobile obligations or make web acceptance equivalent to app-store acceptance.

Permissions and Rights Without Unnecessary Barriers

Request camera, location and notification capabilities when used and with the minimum permission, providing an explanation and an appropriate alternative on refusal. Operating-system permission is not an independent legal basis for processing. Protect tokens and keys with appropriate secure-storage tools, and minimise lock-screen data. For apps supporting account creation, Apple requires that deletion can be initiated within the app; it does not generally require immediate, automatic deletion. Apply Google's requirements for an in-app process and a web link to request deletion within their scope, explaining the timeframe and lawful retention.[8][9]

Compatible Transfers and Updates

Examine app-store transfer eligibility, identifiers, services, signing and permissions. For Apple, an Apple Pay merchant identifier does not transfer automatically with the app. The effects on Keychain, APNs, sign-in and the services in use require a handling plan. For Google, not all integration settings, permissions and reports transfer. Re-establish integrations and test the first release after transfer. The app-store process does not provide a blanket Saudi legal basis for transferring platform data.[10][12]

The release plan defines server compatibility, local data migration, older clients, failed updates and emergency fixes. Do not assume immediate update downloads, forced rollback on every device or remote removal of a version. Review digital purchases, payment methods, tracking and app-store policies according to the product and market. Review the distinct cloned version under template-app policies, not merely by adding a new logo.[11]

Acceptance Through Two Paths

Internal engineering and legal acceptance are required, as is app-store acceptance where distribution requires it. Approval through one path does not replace the other.

22 Acceptance Gates, Alignment, Use and Corrections

A launch or transition decision is incomplete without applicable evidence and a person responsible for follow-up.

Before Launch and Transfer

The scope decision, legal bases, rights, suppliers, policies, permissions, retention, incident plan, release evidence and journeys must be assembled in a proportionate acceptance file. Each test has a version, environment, synthetic input and expected result, followed by an actual result and evidence when performed. Block launch within the scope affected by a missing licence, legal basis, rights instrument or necessary approval, a data breach, exposed secret, or inability to restore or achieve required separation. Do not disable a sound public service without reason.

- Experience acceptance: short steps, clear rights and costs, and refusal of an option that does not block an unrelated service, together with Arabic and accessibility.
- Protection and data acceptance: verified authorisation and rejection, preserved audit records, redacted exports, and destruction that restoration does not reverse.
- Independence and transition acceptance: rebuilding and operation by a replacement team, an independent copy, effective rights and approvals, and actual closure of previous access methods.

Alignment Without Harm Outside Its Scope

Alignment of an existing product begins by identifying the authorised project, reviewing a baseline, flows and permissions, and preserving a restore point. This is followed by a defined change, a targeted test, gradual deployment, monitoring and a rollback plan. Preserve functions and historical documents outside the scope. Contain unlawful processing or ongoing harm without using gradual implementation to perpetuate it. Shutdown includes notification, rights, settlement of obligations, destruction and lawful retention according to the activity, not merely closing the interface and leaving unidentified resources.

Truthful Approval

The responsible person records what has been satisfied, what remains, the reason for blocking and the person responsible for remediation. Do not mark as 'complete' anything awaiting external approval. Do not attribute to this reference any test or transfer results, or a certificate, that have not been issued.

Use and Corrections

Advice for those wishing to benefit from this reference: apply it to the extent relevant to your activity, data and suppliers. Start with the simplest sound service, link your decisions to an accountable person and evidence, and seek specialist assistance when needed. Corrections are welcome. Institutional review maintains the quality of the reference and keeps pace with changes in laws and technologies, without turning the goal of due care into an absolute guarantee.

Inquiries and contact

WhatsApp 0555444959

ceo@2030.sa.vision

Corrections welcome

WhatsApp 0566232776

rijalalwatan.com@gmail.com

An Improvement Process

Submit a correction specifying the location, proposed wording and source where available. It is reviewed and approved in a new version, with the change history preserved.

23 Reference sources

Legal sources apply within their scope. Technical standards and supplier policies are reviewed at implementation and change.

[1] SDAIA – Personal Data Protection Law

Amended text; Articles 1, 4-8, 10-13, 15-19 and 29, according to the subject of the citation.

https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL

[2] SDAIA – Implementing Regulation of the Personal Data Protection Law

Articles 1, 3-12, 15-20, 23-25 and 32-33; rights, notices, consent, processors, minimisation, incidents, assessments and records.

https://dgp.sdaia.gov.sa/wps/portal/pdp/knowledgecenter/details/PDPL2

[3] SDAIA – Regulation on Personal Data Transfer Outside the Kingdom

Version 2.0, August 2024; transfer conditions, routes and assessment, read with Article 29 of the Law.

https://sdaia.gov.sa/Documents/RegulationonPersonalDataAR.pdf

[4] National Cybersecurity Authority – Essential Cybersecurity Controls

ECC-2:2024; scope-of-application section, without extending mandatory applicability to all private entities.

https://cdn.nca.gov.sa/api/files/public/upload/29a9e86a-595f-4af9-8db5-88715a458a14_ECC-2-2024---NCA.pdf

[5] OWASP – Logging Cheat Sheet

Event sources, actor identity, context, outcome, and exclusion of unnecessary data and secrets.

https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

[6] GitHub – Managing Deploy Keys

The section on deploy-key disadvantages; independence from the creator's membership and persistence of the key after the creator is removed.

https://docs.github.com/v3/guides/managing-deploy-keys

[7] MDN – Making Progressive Web Apps Installable

Sections on installability, the manifest and browser support; a service worker is not a condition of installation itself.

https://developer.mozilla.org/en-US/docs/Web/Progressive_web_apps/Guides/Making_PWAs_installable

[8] Apple – Initiating Account Deletion Within an App

Providing deletion initiation for an app supporting account creation; immediate, automatic deletion is not generally required.

https://developer.apple.com/help/app-review/guideline-reference/5-1-1-account-deletion/

[9] Google Play – Account Deletion Requirements

The in-app deletion-request process and web link, within the scope of the account-deletion policy.

https://support.google.com/googleplay/android-developer/answer/13327111?hl=en

[10] Apple — Overview of App Transfer

Transfer effects on Apple Pay, Keychain, APNs and the associated services in use.

https://developer.apple.com/help/app-store-connect/transfer-an-app/overview-of-app-transfer/

[11] Apple — App Review Guidelines

Clause 4.2.6 on commercial template apps, and product-review conditions according to the product's features.

https://developer.apple.com/app-store/review/guidelines/

[12] Google Play — Transfer Apps to a Different Developer Account

App transfer and the items, permission settings, integrations and reports that do not all transfer automatically.

https://support.google.com/googleplay/android-developer/answer/6230247?hl=ar

[13] Umm Al-Qura — Implementing Regulation of the Copyright Law

Published 31 July 2026; Articles 20 and 22 and provisions on licences and rights; an express written instrument is required for deliverables and exploitation.

https://www.uqn.gov.sa/decisions-and-regulations/4001498

[14] Bureau of Experts — E-Commerce Law

Articles 6-8 and 13-14; disclosure, offers, invoices, and rights relating to rescission and delay under their respective conditions.

https://laws.boe.gov.sa/BoeLaws/Laws/LawDetails/360de590-0286-4fa5-a243-aa9100c31979/1

[15] Zakat, Tax and Customs Authority — E-Invoicing Regulation

Article Three on persons subject to the Regulation; integration applicability is determined by the applicable requirements and phase notification.

https://zatca.gov.sa/ar/E-Invoicing/Introduction/LawsAndRegulations/Documents/E-invoicing-Regulations.pdf

[16] Saudi Central Bank — Licensed Payment Service Providers

The live licensing list, used to verify the service provider's legal entity and scope when selecting a provider, not to substantiate any particular provider.

https://www.sama.gov.sa/ar-sa/Supervision/LicenseEntities/pages/licensed_payment_service_providers_companies.aspx